

DOSSIER TECHNIQUE

Architecture SecOps & Continuité

Infrastructure Linux multi-sites en auto-hébergement opérationnel

7 années d'exploitation continue - 99,9 % d'uptime
25+ années d'expérience en administration de systèmes Linux exposés

Lionel ROUSSEAU

Administrateur Systèmes Linux & Sécurité Opérationnelle

Certifié CompTIA Security+ et CySA+

<https://github.com/Lionel-Rousseau> • lionel@rousseau.kr

Apprendre en continu, avec exigence et humilité.

Version 2.4 - 7 mai 2026

Avant-propos

Ce document décrit l'infrastructure de production que j'administre depuis fin 2018 dans le cadre de mon activité indépendante (société unipersonnelle que j'ai créée et que je dirige). Il expose concrètement les choix d'architecture, les contrôles de sécurité, les procédures de continuité et les retours d'expérience accumulés sur sept années d'exploitation continue.

L'environnement décrit n'est pas un Lab de démonstration. Il porte une activité économique réelle, accessible 24/7, qui traite en moyenne 170 emails par jour et environ 19 000 requêtes HTTP quotidiennes (chiffres de 2026), sur trois sites physiques interconnectés et 2 serveurs dédiés en hébergement externe. Il a été conçu, déployé et maintenu en autonomie complète, avec une exigence permanente de fiabilité, de cloisonnement et d'auditabilité.

Vocation du document. Donner à un recruteur, un responsable d'exploitation ou un RSSI une vue claire et auditable de mon savoir-faire opérationnel, au-delà de ce qu'un CV permet de transmettre. Le diagramme d'architecture qui accompagne ce dossier en est la représentation visuelle ; le présent texte en explicite les choix.

Note sur l'anonymisation. Les noms commerciaux des entités juridiques opérantes ont été remplacés par des libellés génériques. Les fournisseurs cités (OVH, Cloudflare, etc.) le sont à titre informatif. Aucune adresse IP publique, hostname interne ni élément exploitable à des fins offensives ne figure dans ce document ou son diagramme associé. Par ailleurs, l'infrastructure étant en évolution constante, il se peut que les descriptions à suivre ne reflètent pas dans les moindres détails son état au moment de la lecture de ce document, cependant je m'engage à l'actualiser le plus régulièrement possible.

1. Contexte et objectifs

1.1 Activité supportée

L'infrastructure supporte une activité de e-commerce et de négoce international, multi-canaux (site marchand propre, marketplaces européennes et asiatiques, échanges BtoB transfrontaliers et grand export). Le travail s'effectuant principalement à domicile, l'infrastructure cohabite avec un environnement personnel (postes familiaux, domotique, IoT). C'est devenu un cas de figure courant en télétravail prolongé et je l'ai traité comme un sujet de sécurité plutôt que comme une zone d'ambiguïté : cloisonnement VLAN, ACL Tailscale entre les sites, séparation des sauvegardes.

Quatre exigences fondamentales se sont imposées dès le départ : disponibilité 24/7 de l'activité économique, intégrité de la messagerie professionnelle (réputation IP, conformité SPF/DKIM/DMARC), confidentialité des données clients (RGPD), et résilience aux incidents, qu'ils soient liés à des défaillances matérielles, à des ruptures de service ou à des tentatives d'intrusion. Une cinquième s'est ajoutée avec le télétravail durable : garantir l'isolation effective des domaines pro et perso sur une infrastructure physique partagée.

1.2 Périmètre opérationnel

L'infrastructure se déploie sur six environnements distincts.

- 2 serveurs dédiés en hébergement externe (OVH, Ubuntu LTS) portant les services exposés à Internet : web, mail principal, MX secondaire et sauvegardes hors site.
- 3 sites physiques interconnectés via un mesh VPN sous WireGuard (Tailscale) : un site principal qui héberge le cœur de l'infrastructure interne, un site secondaire (bureau externe) et un site tertiaire (appartement avec domotique).

Cette topologie multi-sites n'est pas seulement une réponse à la dispersion géographique. Elle joue aussi un rôle de cloisonnement : le site secondaire et le site tertiaire constituent chacun un domaine de confiance distinct, rattaché au mesh par des ACL explicites.

1.3 Volumétrie et indicateurs

Indicateur	Valeur observée
Uptime infrastructure	99,9 % cumulé sur 7 ans (interruptions max 3 h pour migrations planifiées, < 30 min en moyenne pour incidents)
Volume mail entrant traité	Environ 170 messages/jour sur 13 domaines (~63 000/an), filtrage Rspamd + RBL + greylisting
Trafic web	En moyenne 19 000 requêtes HTTP/jour, CDN/WAF Cloudflare en frontal
Hyperviseurs Proxmox	1 nœud principal de production, 1 nœud de secours dédié au PCA, 2 nœuds secondaires dont 1 de test
Machines virtuelles	8 VM en production (Debian, Rocky, Oracle Linux, OPNsense FreeBSD, Kali, Parrot, Kodachi)
Serveurs baremetal (dédiés)	2 serveurs hébergés en France sur 2 sites distincts en Datacenter

Indicateur	Valeur observée
Postes endpoint gérés	Linux, Windows 11 Pro, macOS, iOS, Android, Raspberry Pi (domotique, Pimox, exit nodes)
Réseaux logiques (VLAN)	7 segments cloisonnés : Admin, Bureau, Backups, IoT, Lab, Mobile, Distant
Cohabitation pro/perso	2 domaines logiques cloisonnés sur la même infrastructure physique. Pas de débordement détecté en 7 ans.

2. Architecture et choix techniques

2.1 Vue d'ensemble

L'idée directrice est assez classique en sécurité : appliquer plusieurs couches de défense, du plus loin au plus près. En premier rideau, le WAF Cloudflare filtre le trafic web avant même qu'il atteigne mes serveurs publics. Au périmètre du site interne, OPNsense (NGFW + IPS Zenarmor) gère le routage, le NAT et le filtrage applicatif, juste derrière le routeur fibre. Au sein du LAN, la segmentation VLAN avec une politique deny-by-default inter-VLAN assure le cloisonnement horizontal. Enfin, au niveau hôte, le durcissement basé sur les préconisations du CIS et de Lynis, Fail2ban, Snort, RKHunter, Tripwire et l'intégrité des fichiers en continu constituent la dernière ligne. Pour la corrélation et la supervision, j'ai monté un SOC interne basé sur Wazuh (XDR/SIEM) et Security Onion (NSM/IDS).

2.2 Services exposés à Internet

Les services accessibles depuis Internet sont concentrés sur deux serveurs dédiés OVH sous Ubuntu LTS. Ce choix de distribution tient à la durée de support, à la stabilité et à la maturité des paquets sécurité. L'architecture privilégie le regroupement des services applicatifs sur un nœud principal aux ressources confortables, et la séparation géographique des fonctions de sauvegarde et de relais MX secondaire.

Serveur principal, site FR A : il combine la pile web et la pile mail.

- **Web** : Apache 2 en backend, Nginx en reverse proxy SSL/TLS, MySQL pour les bases applicatives, frontalisé par Cloudflare (CDN, WAF, protection anti-DDoS).
- **Mail (MX primaire, priorité 10)** : Postfix pour le SMTP, Dovecot pour IMAP/SMTP-AUTH, Rspamd pour le filtrage anti-spam (RBL, greylisting, sieve), DANE, DKIM/SPF/DMARC avec signature OpenARC, TLS 1.2+ imposé.
- **DNS récursif externe** : Unbound, pour la résolution récursive autonome (indépendance vis-à-vis des resolvers tiers, journalisation locale). Sert également de backup en cas de dysfonctionnement du DNS du réseau local.

Serveur secondaire, site FR B : Il combine la pile stockage et la pile mail secondaire.

- **MX secondaire (priorité 20)** : assure la continuité de la réception mail si le serveur principal devient indisponible, avec re-livraison automatique au rétablissement.
- **Dépôt de sauvegardes externalisées** : reçoit les snapshots rsync/restic chiffrés en conteneurs LUKS, sur un site géographiquement distinct du site FR A.

Ce regroupement à 2 nœuds est un compromis assumé entre coût d'hébergement et résilience. Il garantit la continuité de la réception mail (MX secondaire) et la sauvegarde hors site, tout en concentrant les services applicatifs sur un nœud unique pour optimiser les ressources. L'infrastructure a longtemps tourné sur 3 nœuds entre 2018 et 2024, et un retour à cette configuration est inscrit à la roadmap dès que les conditions le permettront, pour découpler complètement les services web et mail et faciliter les opérations de maintenance applicative.

L'ensemble des services exposés est en dual-stack IPv4/IPv6. Les serveurs OVH disposent d'adresses IPv4 et IPv6 publiques, les zones DNS publient les enregistrements A et AAAA, et les politiques de filtrage périmétrique (Cloudflare, OPNsense) appliquent les mêmes règles sur les deux familles d'adresses. La messagerie est livrée et reçue en IPv6 quand les pairs le supportent, ce qui impose une attention particulière à la conformité SPF (records ip6:) et au reverse DNS IPv6 (PTR).

2.3 Cœur de l'infrastructure interne

Le site principal héberge la majeure partie de l'infrastructure de production interne, déployée principalement sur un serveur Proxmox VE (plateforme MS-A2, AMD Ryzen 9 9955HX, 96 Go de RAM), des serveurs proxmox complémentaires sur 2 mini PCs et un Pimox (Raspberry Pi 5). Les VM hébergées :

- **OPNsense (FreeBSD), firewall et passerelle.** NGFW avec IPS Zenarmor en mode inline, plugin Tailscale router, gestion des VLAN, NAT, VPN site-à-site, terminaison SSL pour les services internes. Le lien WAN 10 Gbps est passé en passthrough direct à la VM pour limiter la latence et garantir la performance.
- **Wazuh (XDR/SIEM).** Agent déployé sur chaque hôte critique, corrélation centralisée des logs firewall, web, mail, système, antivirus, alerting via les règles personnalisées et le ruleset MITRE ATT&CK.
- **Security Onion (Oracle Linux), NSM passif sur les flux nord-sud.** La VM dispose d'une seconde interface dédiée connectée à un port SPAN du switch L2+ principal, configuré pour « mirroring » le trafic transitant vers et depuis Internet (y compris le trafic 10 Gbps en passthrough vers OPNsense). Suricata applique les signatures (Emerging Threats), Zeek extrait les métadonnées de session. La défense est-ouest sur les flux inter-VLAN n'est pas couverte par Security Onion à ce stade : elle s'appuie sur le filtrage OPNsense (ACL inter-VLAN deny-by-default) et sur la corrélation Wazuh des logs hôtes. L'extension de la visibilité NSM aux flux est-ouest est inscrite à la roadmap.
- **Zabbix (Rocky Linux).** Supervision technique (santé hôtes, services, débits, températures, RAID, états SMART), tableaux de bord d'exploitation, escalade vers notifications email et webhooks (en cours de développement).
- **FreeRADIUS et Unbound DNS (Debian 13).** Authentification 802.1X pour les accès Wi-Fi managés, et résolution DNS récursive locale (filtrage DNS de second niveau, blocage de domaines malveillants, journalisation centralisée).
- **Kali Linux (VM d'audit).** Maintenu en permanence pour les opérations courantes de test (scans, vérifications de configuration, audits internes). Les outils offensifs lourds (Metasploit, Exegol) ne sont activés que ponctuellement, sur des cibles d'entraînement isolées (VM Metasploitable ou VM de test) dans le VLAN Lab et déconnectées du reste de la production. Les sessions offensives ne sont pas lancées sans une isolation préalable.
- **Proxmox Backup Server (VM).** Sauvegardes incrémentales dédoublées des VM critiques, vers stockage local (NAS Synology) puis réplication vers les serveurs OVH externalisés.

- **Parrot Security OS 7 et Linux Kodachi 9.** Démarrées ponctuellement pour des tests de sécurité sur le réseau et pour entretenir un niveau de pratique sur certaines applications spécifiques tout en expérimentant de nouvelles en fonction des opportunités.

Le choix du MS-A2 (mini-PC AMD Ryzen 9 9955HX, 96 Go de RAM, 2 ports SFP+ 10Gbps, 2 ports 2,5Gbps, 1 port 2,5Gbps USB et 1 port 5Gbps USB) répond à un compromis assumé entre densité de virtualisation, consommation électrique modérée pour un fonctionnement 24/7 à domicile, et capacité à passer en passthrough une interface 10 Gbps directement à la VM OPNsense (sortie en 10 Gbps sur le switch principal via un port SFP+). Le nœud de PCA HP ProDesk 400 G4 (i5, 16 Go de RAM) est dimensionné pour faire tourner les seuls services critiques en mode dégradé (firewall, DNS, RADIUS sur ports 1 Gbps), sans prétendre reproduire la pleine charge ; l'objectif du PCA est de rétablir et maintenir l'accès Internet, pas l'intégralité de la production. Un serveur Pimox sur Raspberry Pi 5 (16 Go de RAM) sert ponctuellement de sandbox pour de petites VM de test.

2.4 Cloisonnement réseau

Le LAN du site principal est segmenté en 7 VLAN, gérés par un switch L2+ administré via Omada Controller (conteneur Docker), et routés/filtrés par OPNsense avec une politique deny-by-default inter-VLAN.

VLAN	Population	Politique
Admin	Postes admin, switches, serveurs management	Accès depuis Tailscale uniquement, MFA Yubikey, journalisation systématique
Bureau	Postes Windows 11 Pro, macOS, Linux Mint, imprimantes	Sortie Internet via firewall, accès limité aux services internes par règles explicites
Backups	Proxmox Backup Server, NAS Synology, mirroring	Isolé du reste du LAN, accessible en flux push uniquement, deny en sortie
IoT	Domotique, caméras, chauffage, ouvertures, multimédia, Tesla	Sortie Internet autorisée mais filtrée par OPNsense + Zenarmor (catégories, threat intelligence). Aucune communication possible vers les VLAN professionnels. Les passerelles domotique RPi servent de proxies applicatifs pour les équipements locaux.
Lab	VM Metasploitable activable, environnements offensifs ponctuels	Strictement isolé du LAN de production, sortie Internet en deny-all + whitelist explicite, activation à la demande
Mobile	Smartphones, tablettes, laptops invités	Accès Internet, isolation des VLAN sensibles, captive portal envisagé
Distant	Trafic entrant depuis les sites secondaire et tertiaire via mesh VPN Tailscale	Trafic du bureau externe routé via l'exit node du site principal pour bénéficier de l'inspection OPNsense + Zenarmor. ACL Tailscale strictes : le site tertiaire ne dialogue qu'avec un sous-ensemble de cibles nécessaires.

La sortie Internet de chaque VLAN passe par OPNsense et son module Zenarmor (avec abonnement), qui inspecte les flux applicatifs et bloque les destinations malveillantes connues (feeds threat intelligence, catégories de filtrage URL).

2.5 Interconnexion multi-sites avec Tailscale

Tailscale a été retenu pour relier les trois sites. C'est un VPN mesh basé sur WireGuard qui apporte plusieurs avantages opérationnels : zéro configuration de tunnel manuel, chiffrement bout-en-bout, ACL centralisées avec audit, et la possibilité d'utiliser des exit nodes redondants. Les flux d'administration distante entre sites empruntent exclusivement ce mesh. Les ports d'administration ne doivent pas être exposés à Internet directement.

Le site tertiaire (appartement) héberge un Raspberry Pi 4 sous Raspberry Pi OS qui assure deux fonctions : exit node Tailscale (pour la résilience du mesh) et serveur de domotique. Ce nœud n'est pas exposé directement à Internet : son administration s'effectue uniquement par SSH depuis le LAN local du site, et l'interface domotique (Jeedom HTTPS) est accessible à distance via NAT et reverse proxy authentifié. Les ACL Tailscale appliquent un principe de moindre privilège : ce nœud ne peut communiquer qu'avec un nombre limité de cibles désignées.

Le bureau externe (site secondaire) bénéficie d'une politique particulière : son trafic Internet est intégralement routé via l'exit node Tailscale du site principal, ce qui permet de soumettre ses flux à l'inspection OPNsense + Zenarmor de manière homogène avec le LAN principal. En pratique, un poste pro qui travaille depuis le bureau externe applique exactement la même posture de sécurité que s'il était physiquement au siège : politique de filtrage, journalisation, blocage de domaines malveillants. Le site tertiaire, dont les besoins sont essentiellement domotiques, n'a pas cette redirection mais reste soumis à des ACL Tailscale strictes qui l'isolent du domaine professionnel.

2.6 Cohabitation des domaines professionnel et personnel

Le travail s'effectuant à domicile, l'infrastructure héberge sur les mêmes équipements physiques deux domaines distincts qui ne doivent jamais se confondre : le domaine professionnel (services exposés, postes de travail, sauvegardes, données clients) et le domaine personnel (domotique, IoT grand public, postes familiaux, multimédia). Le principe est simple : les équipements personnels ne doivent pas pouvoir initier une connexion vers le domaine professionnel, et aucun équipement professionnel ne doit dépendre d'un service personnel pour son fonctionnement.

La séparation s'appuie sur trois mécanismes complémentaires.

- **Segmentation VLAN dédiée.** Les équipements personnels sont rattachés aux VLAN IoT, Mobile et, selon les usages, Bureau, distincts du VLAN Admin réservé aux équipements professionnels sensibles. Les ACL inter-VLAN appliquent une politique deny-by-default : un objet connecté ne peut sortir que vers Internet, sous filtrage OpnSense/Zenarmor, et jamais vers les VLAN professionnels.
- **ACL Tailscale ciblées.** Sur le mesh VPN, chaque nœud (poste pro, poste familial, RPi domotique) reçoit un jeu d'autorisations. Les flux pro vers perso et inversement sont fermés par défaut.
- **Stockage et sauvegardes séparés.** Les données professionnelles (mail, e-commerce, documents clients) ne transitent jamais sur les volumes ou conteneurs hébergeant des données personnelles. Les sauvegardes rsync/restic chiffrées des deux domaines utilisent des dépôts et des clés de chiffrement distincts (chiffrement surtout pour le domaine pro, les données non-sensibles du domaine perso ne sont pas chiffrées).

Cette séparation fait l'objet de vérifications périodiques (tests de connexions inter-VLAN, audit des logs et du firewall). A ce jour, aucun débordement de domaine n'a été détecté par les contrôles en place pour la période.

3. Contrôles de sécurité

3.1 Durcissement et accès

- **Authentification SSH par clés exclusivement** (mots de passe désactivés sur l'ensemble des hôtes), passphrases protégées, agent forwarding désactivé, ports non standards, AllowUsers explicite.
- **Hardening guidé par les benchmarks CIS** (Ubuntu Security Guide / USG), audits Lynis périodiques avec un score cible visé au-dessus de 85 (actuellement 80), suivi via journal d'exploitation.
- **Bastion d'administration.** Toute action d'administration distante transite par le mesh Tailscale, à l'exception des serveurs OVH, depuis un poste durci avec une authentification MFA Yubikey.
- **Mises à jour de sécurité automatisées** via Ansible avec fenêtres de redémarrage planifiées. Une évolution via unattended-upgrades (Debian/Ubuntu) et dnf-automatic (Rocky), configurés et déployés par Ansible est en cours de développement.
- **Politique deny-by-default** au niveau OPNsense, des switchs (port-security), et des serveurs (UFW ou iptables/nftables, règles minimales).
- **Isolation domotique et IoT.** Les équipements personnels (caméras, thermostat, ouvertures, multimédia) sont concentrés sur le VLAN IoT, avec sortie Internet filtrée et pas de visibilité vers les VLAN professionnels. Les passerelles domotique RPi servent de proxies applicatifs. Les devices IoT ne dialoguent pas directement avec un service du domaine pro.
- **Application uniforme des contrôles aux deux familles d'IP.** Les règles de pare-feu OPNsense, les ACL inter-VLAN, les bannissements Fail2ban et les Active Response Wazuh ciblent symétriquement IPv4 et IPv6. Les logs incluent systématiquement les deux familles d'adresses.

3.2 Détection et réponse

- **Wazuh** centralise les journaux, détecte les écarts d'intégrité (FIM), exécute des évaluations de configuration (SCA), et déclenche des actions automatiques via Active Response (bannissement IP au niveau firewall ; l'isolement de processus est en cours d'évaluation). Le tagging MITRE ATT&CK est utilisé là où les règles natives le supportent, et étendu progressivement aux règles personnalisées.
- **Security Onion, visibilité périmétrique (nord-sud).** La VM dispose d'une seconde interface dédiée connectée à un port SPAN du switch L2+ principal, configuré pour « mirroring » le trafic transitant vers et depuis Internet. Suricata applique les signatures (Emerging Threats), Zeek extrait les métadonnées de session. Les alertes Suricata et les événements Zeek sont remontés vers le manager Wazuh via un agent Wazuh installé sur la VM SO, ce qui permet leur corrélation avec les autres sources (logs hôtes, FIM, authentifications) dans le SIEM central.
- **Fail2ban** protège SSH, Postfix, Dovecot, Apache sur les serveurs OVH et historiquement les Raspberry Pi contre les attaques par brute force, avec bannissements longs. Les remontées doivent encore être centralisées et exploitées vers le firewall du réseau interne.
- **Contrôle d'intégrité.** RKHunter et chkrootkit pour la détection de rootkits, Tripwire pour la base de signatures de fichiers système, ClamAV pour les flux mail entrants. Actif principalement sur les serveurs externes.
- **Threat hunting régulier.** Revue manuelle des alertes Wazuh et Security Onion significatives, recherche de patterns dans Security Onion (DNS suspects, beaconing C2, exfiltration). L'objectif est une revue au moins une fois par semaine en fonction de l'activité et de l'actualité des CVE.

En complément du tandem Wazuh/Security Onion, 2 outils plus classiques apportent une couche supplémentaire de visibilité quotidienne :

Snort qui tourne avec des règles communautaires ciblées sur les services exposés (web & mail) fait des remontées quotidiennes par mail.

Logwatch envoie chaque matin par email un bilan synthétique des événements système et applicatifs des dernières 24 heures, sur les serveurs externes d'OVH.

Ce bilan quotidien tenu hors SIEM est volontairement simple : il force à garder un œil sur les hôtes individuellement et à repérer rapidement les déviations qui n'auraient pas franchi les seuils d'alerte du SIEM, comme un démon qui redémarre plus souvent que d'habitude ou un volume de mails sortants atypique. C'est aussi le reliquat de contrôles réalisés avant l'arrivée de Wazuh et de Security Onion.

3.3 Sécurité de la messagerie

La messagerie est traitée comme un service critique, autant pour la continuité de l'activité que pour la réputation IP. La même attention est portée sur l'ensemble des domaines, qu'ils soient professionnels ou privés. Les contrôles déployés :

- SPF (record dédié, -all), DKIM (signature 2048 bits, rotation programmée des clés), DMARC (politique de quarantaine, choisie pour des raisons de fiabilité plutôt que de strict reject, avec rapports agrégés et forensic ponctuel).
- OpenARC pour la chaîne d'authentification quand un message transite par plusieurs relais. Actuellement en version 1.0, un passage à la version 1.3 avec clé en 2048 bits est programmé au printemps 2026.
- TLS 1.2 minimum (pour la compatibilité) imposé sur les sessions SMTP entrantes et sortantes, certificats Let's Encrypt renouvelés automatiquement (Certbot avec hooks de rechargement Postfix/Dovecot), Ephemeral DH (DHE/ECDHE).
- Filtrage Rspamd : RBL multiples, Abusix Guardian Mail (blocklists et zones), greylisting adaptatif, scoring bayésien, vérifications DKIM/SPF/DMARC en réception, DANE, Sieve pour le tri.
- OpenPGP via Kleopatra pour la signature et le chiffrement ponctuel de messages sensibles.

3.4 Gestion des secrets

La gestion des secrets s'articule autour de trois composantes complémentaires, chacune adressée à un type d'usage spécifique.

- **Secrets utilisateur** (mots de passe web, comptes professionnels, sessions applicatives) : Proton Pass avec MFA Yubikey, zero-knowledge, accessible mobile et navigateur.
- **Secrets opérationnels** (clés SSH techniques, tokens API d'infrastructure et d'automatisation, credentials de service, mots de passe LUKS, clés de chiffrement de sauvegardes, codes de récupération MFA) : **pass**, le gestionnaire Unix standard, chiffré GPG avec clé maître stockée sur Yubikey. Le store est versionné dans un dépôt Git privé pour traçabilité et synchronisation entre machines. Le déploiement de pass est en cours, avec migration progressive des secrets opérationnels depuis leur stockage actuel.
- **Clés cryptographiques personnelles** (PGP, certificats S/MIME) : Kleopatra (GPG) avec clés sur Yubikey lorsque l'usage le permet.

J'ai envisagé l'hypothèse d'un coffre-fort plus pro, type Vaultwarden ou HashiCorp Vault avant de me résoudre à rester sur pass. Pour un seul administrateur, cela n'apporte pas de bénéfices réels. Pour un usage proche au quotidien, pass se contente de GPG et d'un dépôt Git, et la structure hiérarchique

du store (api/, ssh/, infra/, db/, backups/) reste simple. L'usage GPG s'intègre facilement à Yubikey que j'utilise déjà.

3.5 Sécurité DNS et DNSSEC

Je gère environ 13 domaines, professionnels comme personnels, en autonomie complète sur trois registrars distincts et ce depuis plus de 25 ans pour certains domaines. Le choix du registrar dépend des contraintes de chaque extension.

- **Infomaniak** (registrar suisse) pour la majorité des domaines (.com, .fr, .net, .org, .sarl, etc.). J'ai abandonné Gandi en 2024 après de fortes évolutions tarifaires.
- **Cafe24** (registrar sud-coréen) pour le domaine en .kr. Ce choix s'explique par mes liens personnels et professionnels avec la Corée du Sud (mariage et activité commerciale BtoB). Le domaine .kr ne peut être enregistré que via un registrar accrédité KISA (ce qui exclut les registrars français) et par un résident sud-coréen.
- **Netim** pour le domaine .aero, extension restreinte au secteur aéronautique et peu prise en charge par les autres registrars.

Les zones DNS sont éditées et maintenues directement (records A, AAAA, MX, SPF, DKIM, DMARC, CAA, SRV, TXT divers), sans délégation à un service tiers de gestion DNS. Cette gestion en propre permet une réactivité immédiate sur les ajustements (rotation DKIM, ajout d'enregistrements SPF, déploiement CAA) et garantit la traçabilité complète des modifications.

DNSSEC est activé sur l'ensemble des domaines à l'exception du .kr (Cafe24 ne propose pas DNSSEC pour cette extension). La signature de zone protège contre les attaques de cache poisoning et garantit l'authenticité des réponses DNS bout en bout.

Les enregistrements CAA sont systématiquement déployés pour restreindre l'émission de certificats SSL aux seules autorités autorisées (Let's Encrypt). La quasi intégralité des certificats SSL utilisés sont créés et renouvelés via Let's Encrypt. Il reste encore quelques certificats SSL Gandi valides.

4. Continuité et plan de reprise

4.1 Stratégie de sauvegarde, règle 3-2-1

Toute donnée critique existe en au moins trois exemplaires, sur deux médias différents, dont un hors site.

- **Exemplaire 1** : données sur le système d'origine.
- **Exemplaire 2** : Rsync/Restic sur le NAS Synology, ou snapshot incrémental Proxmox Backup Server (déduplication, chiffrement) sur son disque, dans le VLAN Backups isolé.
- **Exemplaire 3** : sauvegarde restic/rsync chiffrée (AES-256, conteneurs LUKS) répliquée vers un serveur OVH, géographiquement distinct du site principal.

Pour les données hébergées sur le NAS Synology (dont les plus sensibles), une copie quotidienne est conservée sur support amovible, connecté au NAS et stocké en armoire informatique sous clé.

4.2 RPO et RTO cibles

Service	RPO cible	RTO cible	Test
Site web e-commerce	1 h	1 h	Mensuel
Messagerie principale	15 min	1 h	Mensuel
Bases de données applicatives	1 h	1 h	Mensuel
Infrastructure interne (VM Proxmox)	24 h	2 h	Trimestriel

Les tests de restauration ne sont pas qu'un contrôle théorique : à intervalle régulier, une VM ou une base est restaurée sur l'environnement de secours, et les écarts (durée réelle, intégrité, conformité) sont suivis.

4.3 Plan de continuité, bascule du firewall et des services critiques

OPNsense, FreeRADIUS et Unbound DNS, hébergés sur le nœud Proxmox principal (MS-A2 Ryzen 9, 96 Go de RAM), constituent un point sensible identifié : leur indisponibilité bloque l'accès Internet du LAN principal et l'authentification Wi-Fi managée. Le PCA repose sur un nœud Proxmox de secours dédié, un HP ProDesk 400 G4 (i5, 16 Go de RAM), qui héberge en miroir une copie de la VM OPNsense (NGFW + IPS Zenarmor + Tailscale Router) et une copie de la VM Debian (FreeRADIUS + Unbound DNS).

Les configurations sont synchronisées toutes les 24 heures via Proxmox Backup Server, avec une rétention de 2 jours. La procédure de bascule est documentée et testée régulièrement ; elle vise à ramener l'accès Internet en moins de quinze minutes en cas de perte du nœud primaire. Une évolution vers un mécanisme semi-automatique via heartbeat CARP/VRRP est inscrite à la roadmap, pour basculer plus tôt et avec moins d'intervention manuelle.

4.4 Gestion des incidents

Chaque incident sécurité ou de production détecté est immédiatement analysé. Première étape, qualification : gravité, périmètre touché. Ensuite, confinement immédiat si nécessaire (isolation réseau, révocation des identifiants exposés). Puis investigation à partir des logs Wazuh et Security Onion, avec reconstruction du fil temporel. Vient ensuite la remédiation (patch, durcissement complémentaire, contournement...), et enfin une documentation succincte sur les leçons apprises et les actions correctives apportées. Sur les 7 dernières années, aucune fuite de données n'a été identifiée et il n'y a pas eu d'interruption de service liée à un incident de sécurité dépassant les 3 h.

5. Automatisation et industrialisation

Travailler seul m'a vite poussé à automatiser tout ce qui pouvait l'être. Trois outils se sont imposés au fil des années.

Bash scripting pour le quotidien

Les tâches récurrentes d'exploitation sont scriptées et planifiées via systemd timers ou cron : rotations de logs, vérifications de santé applicative, tests de bout en bout des services exposés (heartbeat HTTPS, envoi/réception d'un message témoin, vérification SSL), génération de rapports hebdomadaires, sauvegardes. Les scripts critiques sont conçus pour être idempotents et journalisent

leur exécution. Des scripts complémentaires de contrôle de logs viennent vérifier quotidiennement la bonne exécution des opérations.

Git pour la traçabilité

Une grande partie des fichiers d'administration (playbooks Ansible, scripts Bash, configurations de référence, règles Wazuh personnalisées, store de secrets pass) est versionnée dans des dépôts Git privés. Chaque changement passe par un commit descriptif, et les modifications sensibles peuvent être identifiées via tags pour faciliter le retour arrière.

Généralisation progressive d'Ansible pour les configurations

Depuis quelques mois, les configurations système, les politiques de durcissement, les déploiements de services et la gestion des comptes sont progressivement intégrés dans des playbooks Ansible. L'objectif visé est d'automatiser les modifications : elles sont codées, testées sur une VM de pré-production, puis appliquées en prod via un playbook. Ce mode opératoire garantit la reproductibilité d'un serveur en cas de réinstallation et la traçabilité des changements. C'est un mode de travail en cours de généralisation sur l'infrastructure, certains services restent à être intégrés à ce processus.

6. Roadmap d'amélioration continue

L'architecture a fait ses preuves sur sept années et a continuellement évolué pour devenir ce qu'elle est aujourd'hui. Elle est donc en amélioration constante. Les principaux chantiers identifiés et programmés pour les douze prochains mois :

Court terme (0 à 6 mois)

- **Intégration Security Onion ↔ Wazuh.** Déploiement d'un agent Wazuh sur la VM Security Onion pour remonter les alertes Suricata et les événements Zeek vers le manager, consolider la vue SOC et homogénéiser le tagging MITRE ATT&CK entre sources hôte et réseau.
- **Industrialisation des playbooks Ansible publics anonymisés** sur GitHub : durcissement Debian, déploiement Wazuh, déploiement Postfix/Rspamd. Objectif portfolio public.
- **Renforcement du PCA OPNsense.** Passage à une bascule semi-automatique via heartbeat CARP/VRRP plutôt que manuelle, avec synchronisation continue plutôt que cycle 24 h. Un investissement matériel est prévu pour garantir une symétrie de configuration mais le prix actuel de la RAM en retarde l'acquisition.
- **IDS DNS sur Unbound** (passive DNS, détection de DGA et de tunneling DNS), avec remontée vers Wazuh.

Moyen terme (6 à 12 mois)

- **Migration du Lab offensif sur un Proxmox dédié physiquement séparé:** pour éliminer définitivement le risque résiduel de pivotement depuis le VLAN Lab vers la production.
- **Extension de la visibilité NSM** aux flux est-ouest. Configuration d'un port SPAN ou de taps additionnels dédiés au trafic inter-VLAN, avec dimensionnement adapté de la VM Security Onion. Ce chantier complétera la défense est-ouest actuelle (filtrage OPNsense + corrélation Wazuh) par une inspection paquet effective sur les mouvements latéraux.
- **POC HashiCorp Vault dans le VLAN Lab.** Étude des cas d'usage en rotation dynamique (credentials MariaDB, certificats SSH éphémères) pour évaluer la pertinence d'une migration partielle des secrets opérationnels les plus sensibles.
- **Déploiement d'un EDR léger** sur les postes endpoint (Wazuh agent étendu ou solution complémentaire), avec corrélation centralisée.

- **Découplage des services web et mail** sur deux serveurs dédiés OVH distincts, retour à une architecture 3 nœuds, pour améliorer la résilience opérationnelle et faciliter les opérations de maintenance applicative.

Long terme

- **Migration progressive vers des conteneurs LXC plutôt que des VM full** pour les services peu coûteux (DNS secondaire, monitoring, backups), afin d'alléger les besoins en ressources et accélérer les déploiements.
- **Étude d'un passage à NixOS** pour les serveurs OVH publics, pour bénéficier de la reproductibilité atomique et du rollback transactionnel.

Exploration AI / automatisation SecOps

Une démarche d'expérimentation a été engagée sur des cas d'usage strictement opérationnels, dans un environnement délibérément isolé du périmètre de production.

- **n8n** Une plateforme self-hostée a été déployée et une démarche d'industrialisation de workflows d'orchestration SecOps est planifiée : enrichissement d'alertes par croisement avec sources Threat Intel publiques, notification multi-canal. Premiers tests de workflows concrets ciblés sur la roadmap court terme.
- **OpenClaw** comme agent personnel SecOps : framework d'agent open-source capable d'exécuter des tâches concrètes (lecture de fichiers, exécution shell, navigation web), évalué en lab pour mesurer l'apport sur le triage et l'analyse. **Le backend LLM utilisé en phase actuelle est l'API OpenAI ; un passage à un modèle hébergé localement (Ollama) est inscrit à la roadmap pour les usages manipulant des données potentiellement sensibles.** Cas d'usage cibles : synthèse en langage naturel des alertes Wazuh, identification de patterns de bruit pour optimiser les règles, génération de premiers brouillons de rapports d'incident.

Architecture d'isolation actuelle : l'agent OpenClaw est exécuté ponctuellement sur une VM du VLAN Lab, isolée du LAN de production, et n'a pas accès aux environnements de production ou aux données clients.

Garde-fous identifiés à implémenter avant tout passage à un usage régulier :

- **Wrapper de pré-traitement obligatoire** entre la source de logs (Wazuh JSON) et l'agent : anonymisation (hashing identifiants, masquage IPs internes, retrait de tokens), filtrage par catégorie d'alerte, délimitation XML avec instructions explicites de non-exécution. Aucun accès direct de l'agent aux logs bruts.
- **Filtrage défensif** des patterns d'injection connus dans les contenus ingérés.
- **Sortie réseau de l'agent filtrée par OPNsense** en deny-all et whitelist explicite des seules APIs LLM utilisées, avec journalisation Wazuh des tentatives non autorisées.
- **Inscription au registre RGPD** du transfert de données vers fournisseur LLM externe, et passage à modèle local pour les cas d'usage manipulant des données identifiantes.

Cette phase d'expérimentation est basée sur la prudence, la découverte progressive et une exposition maîtrisée. Un retour d'expérience sera publié sur le portfolio public au terme de cette phase, avec un retour particulier sur la mise en place des contrôles.

7. Retours d'expérience

Sept années d'exploitation continue ont laissé quelques traces. Voici les leçons que je retiens, illustrées par des situations concrètes.

Faire simple, c'est assurer une fiabilité dans le temps

Au printemps 2024, j'ai dû arbitrer économiquement le passage de trois à deux serveurs dédiés OVH. Sur le papier, c'était une régression : web et mail se retrouvaient sur le même nœud, ce qui aurait été inenvisageable cinq ans plus tôt. En pratique, le MX secondaire géographiquement distant et la sauvegarde externalisée préservaient l'essentiel : la continuité de la réception mail et la possibilité de tout reconstruire ailleurs en cas de problème majeur. Ce que j'ai appris en faisant ce choix, c'est identifier les redondances vraiment indispensables. Le retour à trois nœuds reste prévu, mais pas à n'importe quel prix. Le même principe a guidé le choix de passer plutôt qu'une plateforme distribuée : l'outil le plus simple, qui est aussi souvent le plus rapide à prendre en main, répond au besoin en libérant du temps pour les vrais sujets.

Une sauvegarde qui n'a pas été restaurée n'est pas fiable

C'est pourtant une chanson connue mais la leçon est amère : une sauvegarde non testée est une sauvegarde inexistante. Sur la période récente, deux tests de restauration mensuels m'ont rattrapé. Une fois, après une série de modifications d'un script de sauvegardes de dossiers et de bases de données importantes, je me suis aperçu après 10 jours qu'une erreur de saisie bloquait le dump d'une base de données au milieu d'une série de commandes. Une autre fois, j'avais pris pour (très mauvaise) habitude de simplement constater que la date et la taille d'un backup étaient conformes sans regarder automatiquement le fichier jusqu'au jour où j'ai découvert que le backup plantait en cours de process laissant une sauvegarde système complètement inexploitable.... et que je répliquais, en plus, sur les autres supports. Sans ces tests, j'aurais découvert ces problèmes dans les pires conditions et les conséquences auraient été sévères. Aujourd'hui, le test mensuel n'est plus une option et je passe en revue les cibles à tour de rôle.

Les bonnes pratiques, pour se protéger de ses propres erreurs

Récemment, j'ai partagé un fichier ossec.conf dans une discussion technique sans réaliser qu'il contenait deux clés d'API en clair. Sept ans à tenir une infrastructure propre, et je me suis fait avoir par mon propre fichier de configuration en cinq secondes. La clé Maltiverse était heureusement modifiable, je l'ai régénérée immédiatement ; pour la clé VirusTotal Community qui n'a pas de rotation self-service, j'ai supprimé le compte et en ai créé un nouveau avec une autre adresse mail. C'est par le biais de cette erreur que j'ai opté pour le dépôt de ce fichier de configuration sur Git pour être utilisé comme un template dont les secrets, récupérés via pass, ne sont intégrés qu'au moment du déploiement sur la machine Wazu. C'est un bon exemple de remédiation qui transforme un incident en amélioration.

Documenter pour gagner du temps

Travailler seul sur une infrastructure pendant sept ans, c'est faire le pari que je me souviendrai plus tard de ce que j'ai décidé aujourd'hui. Ce pari ne tient que si la documentation suit. Quand j'ai dû réinstaller mon NAS Synology après un crash matériel, j'ai retrouvé un fichier texte avec des notes et des commandes que j'avais intégré dans une tâche cron qui tournait au quotidien. Sans ces notes, j'aurais été obligé de réécrire complètement le script en oubliant les écueils par lesquels j'étais passé, répétant ainsi les erreurs du passé et perdant un temps précieux. La documentation, particulièrement dans un environnement complexe et mouvant est essentielle et j'ai souvent appris à mes dépens à documenter. Quand tout marche on oublie, au moment du crash on réalise... Bien que ce dossier soit réalisé avec un objectif différent, il s'inscrit pourtant dans cette pratique.

Le cloisonnement, ça ne fait pas rêver mais ça tient

Avant 2022, mon LAN était à plat, sans VLAN, et ça fonctionnait. Jusqu'à ce que je me rende compte du nombre important et de la faiblesse de mes objets connectés : caméras d'origines variées, ampoules connectées, thermostats... Le passage à un découpage VLAN strict n'a pas été un projet facile, il s'est étalé dans le temps et a connu quelques déboires (la TV qui ne voit plus le NAS, l'imprimante qui devient invisible aux postes, la Tesla qui ne récupère plus ses mises à jour la nuit). J'ai mis du temps à m'y résoudre, mais le cloisonnement a un effet positif : il protège la vie personnelle des incidents qui pourraient toucher la zone pro, et inversement. C'est probablement la condition pour que le travail à domicile sur une infrastructure partagée reste tenable sans renoncer à la sécurité.